

dailymattr.com: full-site test & audit

Date: 30 September 2026 · Codebase: `Dailymattrmain` (branch `main` @ a462661 plus uncommitted admin work) · Status: audit only, no code changed

2

CRITICAL

9

HIGH

19

MEDIUM

31

LOW

Scope and method. I tested the site live, as well as reading the code, in two environments:

- **Local dev server** (`localhost:5173`): browser testing at desktop (1280×800) and mobile (375×812); form edge cases with outbound requests blocked so nothing reached the database; `curl` probes of every route shape; and an isolated harness that runs `api/admin.js` with *fake* credentials.
- **Production** (`www.dailymattr.com`): read-only requests only (about 120 in total, all GET/HEAD apart from one POST and one DELETE to `/news` to check how it handles methods, which that route ignores).

I also checked the Supabase projects read-only, ran a production build into a scratch folder, and ran `npm audit`.

Not done, on purpose: no forms were submitted to production, no rows were written to any database, and no real admin credentials were used. The new admin panel is **not deployed yet** (production `/admin/` returns 404), so its findings describe what would happen once it ships.

Fix these first

1. **C1, C2:** make the admin API refuse to run without `ADMIN_EMAIL`, `ADMIN_PASSWORD` and a strong `ADMIN_SESSION_SECRET`. Do this before the admin panel is deployed.
2. **H1:** escape the `<title>` on `/news` pages. This is a stored XSS, live in production today.
3. **H2:** remove `fs.strict:false` from `vite.config.js`. The dev server hands out `.env`, including the service-role key.
4. **H3, H4:** point the admin API at the correct Supabase project, apply the `admin_settings` migration, and make login actually use the stored password.
5. **H5–H7:** add the two missing images, add a news sitemap, and fix the 2.4 MB hero preload. These are cheap SEO and speed wins.
6. **H8, M3:** add bot protection and double opt-in to the newsletter and support forms.

Critical

C1	CRITICAL	Admin login accepts an empty email and password if the env vars are missing	Security · Admin API
CAUSE	<code>api/admin.js:51-52</code> compares the input with <code>String(process.env.ADMIN_EMAIL "")</code> and <code>String(process.env.ADMIN_PASSWORD "")</code> . When those variables aren't set in the deployment (for example, forgotten in Vercel), both sides are <code>""</code> and the check passes.		
EVIDENCE	Harness with the admin env vars unset: <code>POST /api/admin?action=login</code> with <code>{"email":"","password":""}</code> returned 200 {"ok":true} and a session cookie. A body of <code>{}</code> also returned 200. The <code>required</code> attributes in the form don't help, because the API can be called directly.		
IMPACT	Anyone could read every support request (names, emails, messages) and call the password endpoint.		
FIX	Fail closed: if <code>ADMIN_EMAIL</code> or <code>ADMIN_PASSWORD</code> is empty, return 503 and never issue a cookie. Reject empty input with 400. Compare with <code>crypto.timingSafeEqual</code> on hashes.		

C2	CRITICAL	Admin session cookies can be forged with the hard-coded fallback secret	Security · Admin API
CAUSE	<code>api/admin.js:15</code> signs with <code>process.env.ADMIN_SESSION_SECRET "change-this-secret"</code> . That fallback string is in the source code, so anyone who can read the source can sign a valid cookie.		
EVIDENCE	Harness with the secret unset: I built a cookie for <code>attacker@evil</code> , signed it with <code>"change-this-secret"</code> , and it passed the auth gate (the response was <code>404 Unknown admin action</code> , which is only returned after authentication succeeds).		
FIX	Throw at startup if the secret is missing or shorter than 32 bytes. Remove the fallback, and never commit example secrets that look usable.		

High

H1	HIGH	Stored XSS: CMS headline is written unescaped into <code><title></code> on <code>/news</code>	Security · News (live)
CAUSE	<code>api/_lib/layout.js:70</code> outputs <code><title>\${title}</title></code> without escaping. <code>router.js:88</code> passes <code>seo.title</code> , the raw <code>cleanHeadline(post.headline)</code> . Every other field I checked is escaped.		
EVIDENCE	I rendered a post with the headline <code>Evil </title><script>...</code> and the output contained a working <code><script></code> . <code>cleanHeadline</code> strips <code>()[]{}</code> , but payloads without those characters (for example <code></code>) still run. The edge cache then serves the payload for up to an hour.		
FIX	Use <code>esc(title)</code> . Also escape <code>published_id</code> in <code>render-article.js:66</code> and <code>seo.js:85</code> (see N6), and add a CSP (M5).		

H2	HIGH	Dev server serves <code>.env</code>, <code>.git</code> and any file on disk	Security · Tooling
CAUSE	<code>vite.config.js:37</code> sets <code>server.fs: { strict: false }</code> (a workaround for the Windows 8.3 short path). This also turns off Vite's built-in block on dotfiles.		
EVIDENCE	<code>GET localhost:5173/.env</code> returned 200 (6.5 KB: the real file, including <code>PIX_SUPABASE_SERVICE_ROLE_KEY</code> , <code>ADMIN_PASSWORD</code> and <code>ADMIN_SESSION_SECRET</code>). <code>/.git/config</code> returned 200 and <code>/@fs/C:/Windows/win.ini</code> returned 200. Production <code>/.env</code> is 404.		
IMPACT	Only local today, because the server listens on <code>[:::1]</code> . Running <code>vite --host</code> (for example, to test on a phone) would expose the service-role key to everyone on the network.		
FIX	Remove <code>strict:false</code> . Use <code>fs.allow: [fs.realpathSync(root)]</code> , or start Vite from the long path.		

H3

HIGH

The admin inbox reads from the wrong Supabase project

Database · Admin API

CAUSE

`api/admin.js:8-9` pairs `SUPABASE_URL` || `VITE_SUPABASE_URL` with `PIX_SUPABASE_SERVICE_ROLE_KEY`. Those belong to different projects.

EVIDENCE

Production: the support bundle writes to `hntlrudlonpsoraxydk` (read from the live JS), but the service key belongs to PixAgent (`coggfnbqqyiqfsxvtaym`). So once deployed, `messages` will fail with "Admin service is not configured or unavailable".

Locally: `.env` points `VITE_SUPABASE_URL` at PixAgent. Listing PixAgent's tables shows only `pix_posts`, `pix_users` and `pix_sessions`; there is no `support_requests` and no `admin_settings`. So the local support form and the admin inbox both fail too, and the committed `dist/` bundle was built against PixAgent.

FIX

Add dedicated `SUPPORT_SUPABASE_URL` / `SUPPORT_SUPABASE_SERVICE_ROLE_KEY` for the `hntlr...` project, set local `VITE_SUPABASE_URL` to match production, and rebuild `dist/`. Apply migration `20260930000000_create_admin_settings.sql` to that project.

H4

HIGH

"Change password" has no effect: login never checks the stored password

Broken feature · Admin

CAUSE

The password action writes a script hash to `admin_settings` (`api/admin.js:63`), but login only compares with `ADMIN_PASSWORD` from env (`:52`). `verify()` is never called. On top of that, the table doesn't exist yet (H3), so the action returns 500.

IMPACT

An admin who "rotates" a leaked password is still exposed, and the UI would say "Password updated."

FIX

At login, if an `admin_settings` row exists, `verify()` against it; otherwise fall back to env. Require the current password to change it, and store a session version in the row so a change invalidates existing cookies.

H5

HIGH

Share image and publisher logo return 404 in production

SEO · All pages

CAUSE

`/assets/og-default.jpg` and `/assets/publisher-logo.png` are referenced by every static page's og/twitter tags, the homepage Organization JSON-LD (`index.html:49`) and `api/_lib/site.js:20-21`. Neither file is in `public/assets/`.

EVIDENCE

Both return 404 on `www.dailymattr.com`. Locally they return 200 `text/html` (the SPA fallback), which hides the problem.

IMPACT

Link previews on WhatsApp, X and LinkedIn have no image, and every `NewsArticle.publisher.logo` is invalid for Google.

FIX

Add a 1200×630 JPG and a 600×120 PNG at those paths.

H6

HIGH

No sitemap for news articles

SEO · News

EVIDENCE

`/sitemap.xml`, `/sitemap-news.xml` and `/news/sitemap.xml` all return 404. `robots.txt` lists only `sitemap-pages.xml` (14 hub URLs, no articles). The helpers already exist but are never used: `queries.js:97-119` (`listRecentForNews`, `listBetween`) and `http.js:10-13` (`CACHE.sitemap*`).

FIX

Add a sitemap route: a Google News sitemap for the last 48 hours plus monthly archive sitemaps. Rewrite it in `vercel.json` and list it in `robots.txt`.

H7

HIGH

Every article preloads the 2.4 MB original PNG it never displays

Performance · News

CAUSE

`router.js:91` preloads `seo.heroImages[0].url` (the `/object/public/` original), while the `<img>` uses a `/render/image/?width=480` WebP with `srcset` (`layout.js:82`).

EVIDENCE

On a production article, the preload is a 2,392,372-byte PNG; the image actually shown is a 29,798-byte WebP.

FIX

Preload the same rendered URL with `imagesrcset` / `imagesizes`, or drop the preload.

H8

HIGH

Newsletter signup can be abused to email anyone and reveals who is subscribed

Security · Privacy · Newsletter

CAUSE

`src/newsletter.js:50-65` posts directly to the `subscribers` edge function (project `ygxdrphajvrbcaxhvcn`), which upserts the address and sends a welcome email right away. There's no captcha, honeypot or double opt-in. The response text tells the visitor whether the address was *already subscribed*, and it silently re-subscribes people who had unsubscribed (`showResult`, lines 22-39).

IMPACT

A script can sign up any addresses, which risks spam complaints, sender-reputation damage and anti-spam law exposure. Anyone can also check whether a given email is on the list.

FIX

Use double opt-in (confirmation email first), add Turnstile or a honeypot, rate-limit per IP and per email in the edge function, and always show the same neutral "Check your inbox" message. Whether the function already rate-limits is unverified; it's in another project.

H9

HIGH

The smoke test for /news crashes before running any check

Tooling · QA

EVIDENCE

`node scripts/smoke-news.mjs` prints `data source: none`, then `ENOENT ... api\_data\pix-snapshot.json` (thrown from `snapshot.js:19`). The snapshot is gitignored and missing, and the script never loads `.env`, so it can't fall back to Supabase.

IMPACT

The only automated check for the SEO/routing layer is silently not running, which is how H1 and M7 got through.

FIX

Load `.env` and use `queries.js`, or commit a small fixture dataset. Run it in CI before deploys.

Medium

M1

MEDIUM

No brute-force protection on admin login

Security · Admin

EVIDENCE

25 rapid wrong-password attempts against `/api/admin?action=login` all returned 401. No 429, delay or lockout.

FIX

Rate-limit per IP and per account (Vercel KV/Upstash or a Supabase table), add a delay after failures, and consider adding 2FA or Supabase Auth.

M2

MEDIUM

Logging out doesn't invalidate the session

Security · Admin

EVIDENCE

Harness: after `logout`, replaying the same cookie still passed the auth gate. The token is stateless and stays valid for 8 hours. A stolen or copied cookie can't be revoked, and changing the password doesn't revoke it either.

FIX

Put a session version (or ID) in the cookie and check it against `admin_settings`. Increment it on logout and password change.

M3

MEDIUM

Support form has no spam or abuse protection

Security · Database

CAUSE

The RLS policy is `insert ... to anon with check (true)`, and there's no honeypot, captcha or throttle. Anyone with the public key can POST straight to `/rest/v1/support_requests` and skip the client checks; for example, `topic` accepts any text up to 80 characters.

FIX

Add Turnstile plus a honeypot, route inserts through an edge function with rate limiting, and add `CHECK (topic IN (...4 topics...))`.

M4

MEDIUM

Missing security headers in production

Security · Deployment

EVIDENCE

Only `Strict-Transport-Security: max-age=63072000` is sent (no `includeSubDomains`). There's no CSP, `X-Frame-Options / frame-ancestors`, `X-Content-Type-Options`, `Referrer-Policy` or `Permissions-Policy`. The site can be framed (clickjacking) and has no second line of defence against H1.

FIX

Add a `/(.*)` headers block in `vercel.json`. The CSP must allow Google Fonts, `*.supabase.co`, inline JSON-LD and the font `onload` swap (via hashes).

M5

MEDIUM

No navigation menu on mobile

Responsive · All pages

EVIDENCE

At 375 px (tested in the browser on `/`, `/news/`, `/newsletter/` and `/support/`), `.nav-links` is `display:none` (`style.css:833`) and there's no menu button. Only the logo and "Download App" are visible. News, Newsletter and Support can only be reached from the footer, and `/newsletter/` has no footer, so on mobile it's a dead end.

FIX

Add a hamburger or drawer menu (a `<button aria-expanded>` plus panel) shared by all pages and by the news layout. Add a footer to the newsletter page.

M6

MEDIUM

`/news/page/0/` returns 200 and is indexable

SEO · News routing

CAUSE

`router.js:39,47` accept `\d{1,4}`, which includes 0. The empty-page guard (`:99`) only checks `n > 1`, so `range(-30,0)` runs.

EVIDENCE

Production `/news/page/0/` and `/news/india/page/0/` return 200 with `index, follow`, one post, and `ItemList position: 0`. `/news/page/0002/` returns 200 instead of a 301.

FIX

Return 404 when `n < 1`, and 301 to the canonical form when the number has leading zeros.

M7

MEDIUM

Adding `?bare=1` to any news URL redirects it to `/news/`

Routing · Caching

CAUSE

Vercel merges the visitor's query string into the rewrite destination, and `api/news.js:11` trusts `bare`.

EVIDENCE

`/news/india/?bare=1` and `/news/<article>?bare=1` both return 301 to `/news/`, and the redirect is cached for a day. It isn't an open redirect, because the target is fixed.

FIX

Only honour `bare` when `p` is empty, or detect the bare path from `req.url`.

M8

MEDIUM

News route renders pages for POST, DELETE and other methods, bypassing the cache

API · Performance

EVIDENCE

`curl -X DELETE https://www.dailymattr.com/news/<article>` returned 200, a full page and `X-Vercel-Cache: MISS`. Each such request hits Supabase directly, which is a cheap way to load the database.

FIX

Return 405 with `Allow: GET, HEAD` for any other method. Apply the same check in `api/admin.js`.

M9

MEDIUM

Render-blocking `site.css` is never cached

Performance · Caching

EVIDENCE

`vercel.json` gives `/assets/site.css` `no-cache, no-store, must-revalidate`, so every news page view downloads it again (about 30 KB). The news pages already version the URL with `?v=<commit>`, which makes long caching safe.

FIX

Use `public, max-age=31536000, immutable` (the `?v=` handles cache busting), or at least `no-cache` without `no-store` so browsers can revalidate with a 304.

M10

MEDIUM

Article og:image is the full-resolution original with the wrong declared size

SEO · Performance

EVIDENCE

The og:image is an 822 KB, 2078×3840 JPEG, but it's declared as 920×1700 (hard-coded in `seo.js:93-94`). It's portrait, so `summary_large_image` cards crop it badly.

FIX

Use a rendered 1200-wide (ideally landscape) variant and emit its real dimensions.

M11

MEDIUM

Homepage phone animation uses about 270 MB of memory and several MB of downloads

Performance · Home

EVIDENCE

`dphone-seq1.webp` and `dphone-seq2.webp` are 1.5 MB each at 5632×4136, about 89 MB each once decoded, and both stay in memory for the whole visit (`phoneSeq.js:204,214`). The mobile `phone-seq.webp` is 3688×3385 (about 48 MB decoded). `phone-frame.png` (883 KB) loads for every visitor. The flying-phone screens (`index.html:377-380`) have no `?v=5` while the same files elsewhere do, so they are probably downloaded twice (about 590 KB).

FIX

Split or downscale the sprite sheets, `close()` `ImageBitmaps` once they've been drawn, convert the frame to WebP and lazy-load it, and use the same `?v` on every screen image.

M12

MEDIUM

"Reduce motion" is only honoured for the intro

Accessibility

EVIDENCE

`main.js:851` checks `prefers-reduced-motion` only in `playIntro`. Lenis smooth scroll, the scroll-driven phone flight, the 340% pinned section, the parallax, the infinite marquee (`style.css:284`) and the `.shine` loop (`:117`) all ignore it.

FIX

When reduce motion is on, skip Lenis and the scrubbed timelines, and add CSS overrides for the marquee and shine.

M13

MEDIUM

A JavaScript failure leaves the homepage permanently black

Resilience · Home

CAUSE

`#intro` (`index.html:56`, `style.css:49`) is a fixed full-screen overlay that only `playIntro()` removes. Any module-load or runtime error, or a blocked script, leaves it covering the page.

FIX

Add a CSS fallback animation that fades it out after about 3 s, or inject the overlay from JavaScript.

M14

MEDIUM

Colour contrast fails WCAG AA in several places

Accessibility

EVIDENCE

Footer headings `#97979e` on `#e5e4e8`: **2.29:1**. Support placeholders: 2.70. Footer blue wordmark: 3.10. White on `#3979ff` (all `.btn-dark`, the news tabs and CTA): 3.92. `#3979ff` links on white (`.news-meta a`, `.article-source a`, 7.7 px `.brand-tagline`): 3.92. `.footer-copy`: 4.17. The target for normal text is 4.5.

FIX

Darken the brand blue for text use (for example `#2a5fd6` or darker) and darken the footer greys.

M15

MEDIUM

Support "topic" dropdown is hard to use by keyboard and screen reader

Accessibility · Support

EVIDENCE

When closed, the menu is only made invisible (`style.css:616-624`), so its 4 options stay in the Tab order. After choosing an option or pressing Esc, focus stays on an invisible option (`support.js:87,97`). There's no arrow-key support and no `aria-controls`, and the wrapping `<label>` makes the trigger's accessible name include every option's text.

FIX

Use a native `<select>`, or add `inert / visibility:hidden` when closed, return focus to the trigger, and support arrow keys.

M16 **MEDIUM** **Broken footer links on /support/** Bug · Support

EVIDENCE `support/index.html:121-123` link to `#top`, `#showcase` and `#features`, which don't exist on that page, so clicking them does nothing.

FIX Change them to `/`, `/#showcase` and `/#features`.

M17 **MEDIUM** **Newsletter page is missing SEO basics** SEO · Newsletter

EVIDENCE `newsletter/index.html` has no canonical, og/twitter tags, robots meta, JSON-LD, `favicon.ico` or `apple-touch-icon`. It isn't in `sitemap-pages.xml`, and production serves both `/newsletter` and `/newsletter/` with 200 (duplicate URLs).

FIX Copy the head block from `/support/`, add the page to the sitemap, and redirect the version without a slash.

M18 **MEDIUM** **Admin responses aren't marked no-store, and the inbox isn't paginated** Security · Admin

EVIDENCE The `messages` response carries customer PII but sends no `Cache-Control` header (only `Content-Type` and `Content-Length`). The query has no pagination, so above 1,000 rows (Supabase's default cap) older messages silently disappear.

FIX Send `Cache-Control: no-store` on every admin response, and paginate with `.range()`.

M19 **MEDIUM** **Navigation is inconsistent between pages** UX · Content

EVIDENCE Newsletter is missing from the header and footer on support and all three legal pages, while the homepage and the news NAV include it. The same item is labelled "What we are", "What are we" and "What is Mattr" on different pages. Legal pages have a "DailyMattr ▼" link that opens the homepage in a new tab, and an "Account" avatar that goes to `/#top`. "Download App" on subpages links only to Google Play. Production `/newsletter/` is also missing News; that's fixed in your uncommitted changes.

FIX Generate the header and footer from one shared source (as `api/_lib/site.js` does for news).

Low

ID	ISSUE	CAUSE / EVIDENCE	SUGGESTED FIX
L1	Admin API returns 500 for bad input	Malformed JSON gives 500; a cookie with a short signature gives 500 because <code>timingSafeEqual</code> throws on unequal lengths (<code>admin.js:24</code>). Both tested.	Check lengths first and return 401; catch JSON errors and return 400.
L2	Admin login trims the password and uses plain <code>===</code>	<code>admin.js:48,52</code> : <code>"pass"</code> is accepted as <code>"pass"</code> , and the comparison isn't constant-time.	Don't trim passwords; compare hashes with <code>timingSafeEqual</code> .
L3	Admin dashboard shows hard-coded, fake status	<code>admin/dashboard/index.html</code> : "Wednesday · 30 September 2026", "Good morning, admin." and "System healthy / All services operational" are static text.	Render the date and greeting in JS; drop the fake health badge or wire it to a real check.
L4	Admin session isn't tied to the configured email	A cookie stays valid after <code>ADMIN_EMAIL</code> changes; only the secret is checked.	Check <code>data.email === ADMIN_EMAIL</code> (or the session version, M2).

ID	ISSUE	CAUSE / EVIDENCE	SUGGESTED FIX
L5	Apex redirect is temporary	<code>dailymattr.com</code> → <code>www</code> is a 307, not a 308; <code>http://dailymattr.com/</code> takes two hops.	Make the apex redirect permanent in the Vercel domain settings.
L6	Stale images after updates	Non-hashed <code>/assets/*</code> images are cached for 1 hour plus a day of SWR, and <code>?v=</code> is used inconsistently. <code>icon-pix-lightning.png</code> changed today with no version bump.	Import images through Vite (hashed names) or bump <code>?v=</code> consistently.
L7	Unused files are deployed publicly	<code>Frame 175 (3).png</code> , <code>WhatsApp Image 2026-09-29 at 4.50.07 PM.jpeg</code> (200 in production), <code>card-wraps.jpg</code> , <code>icon-articles.svg</code> and <code>iphone.glb</code> (2.1 MB, only used by <code>?capture</code>). Filenames contain spaces. Both screenshots were checked: nothing private in them.	Delete them, or move the dev-only files out of <code>public/</code> .
L8	Dead hero word-rotator code	<code>main.js:626-636</code> animates <code>.word-track</code> , which is commented out of the HTML. The browser console shows "GSAP target <code>.word-track</code> not found" 3 times on every load.	Remove the code, or guard it with <code>if (words)</code> .
L9	Mobile footer tap targets are small	Measured at 375 px: footer links are 18 px tall (the guideline is 24 px minimum; 44 px is recommended).	Add vertical padding to the footer links on mobile.
L10	Heading structure and landmarks	<code>h2</code> → <code>h4</code> in footers; <code>h1</code> → <code>h4</code> for "On this page" on the legal pages; the footer sits inside <code><main></code> on the homepage; there are no skip links; support errors don't set <code>aria-invalid</code> .	Fix the heading levels, move the footer out of <code><main></code> , and add a skip link.
L11	Support message length can mismatch the textarea limit	The client counts UTF-16 units (2,600 emoji are rejected though the database would accept them). Line breaks are submitted as CRLF, so a message within <code>maxLength</code> can be rejected as too long (from the HTML spec; not tested in a browser).	Count with <code>[...str].length</code> after normalising line breaks.
L12	Newsletter minor issues	Server <code>body.error</code> text is shown as-is; the name field has no <code>maxLength</code> ; the email regex accepts <code>a@.com</code> (the browser's email check catches it first).	Map errors to friendly text and add <code>maxLength</code> .
L13	Support page loads all of supabase-js	The support chunk is 222 KB (58 KB gzipped) for a single insert.	Import it on submit, or use plain <code>fetch</code> to PostgREST.
L14	Build chunk-size warning	The <code>phone3d</code> chunk is 645 KB; it's lazy and only used by <code>?capture</code> .	Exclude it from production builds, or silence the warning knowingly.
L15	<code>npm audit</code> : 2 high advisories	<code>nanoid</code> ≤3.3.17 and <code>postcss</code> ≤8.5.22, both transitive dev-only dependencies via Vite. <code>--omit=dev</code> finds 0.	Run <code>npm update vite</code> .
L16	Homepage meta description is too long; sitemap lastmod is static	The description is 180 characters and will be truncated. Every <code>lastmod</code> is 2026-09-19.	Trim it to about 155 characters; generate <code>lastmod</code> at build time.

ID	ISSUE	CAUSE / EVIDENCE	SUGGESTED FIX
N1	ItemList positions wrong on the last page	<code>seo.js:126</code> uses <code>(page-1)*posts.length</code> instead of the page size. <code>/news/states/page/20/</code> starts at 134 instead of 571.	Use <code>PAGE_SIZE</code> .
N2	<code>rel="next"</code> drops the date filter	<code>seo.js:137</code> . The page is noindex, so impact is small.	Append <code>?date=</code> .
N3	Unknown query strings split the edge cache	<code>?utm_source=...</code> and <code>fbclid</code> each cause a cache MISS and a Supabase query.	Ignore or strip unknown parameters before rendering.
N4	500 page is a bare HTML fragment	<code>api/news.js:17</code> sends <code>renderError(500)</code> without <code>page()</code> : no doctype, layout or noindex.	Wrap it in <code>page()</code> with noindex and add <code>Retry-After</code> .
N5	Encoded-path duplicates in production	<code>/news/india%2F</code> and <code>/news/%69ndia/</code> return 200 in production but 404 locally (the dev middleware uses the raw path).	301 non-canonical paths to the canonical URL.
N6	<code>published_id</code> is interpolated unescaped	<code>render-article.js:66</code> (<code>data-prev / data-next</code>) and <code>seo.js:85</code> . An attribute breakout was shown with a non-numeric id. Only exploitable if that column can hold non-digits (unverified).	Validate with <code>isValidId</code> and escape.
N7	News accessibility details	The date filter submits on <code>change</code> (WCAG 3.2.2); the app-gate dialog has no focus trap and doesn't return focus; <code>aria-label</code> is on a plain div; the header nav has no label; the date field shows two calendar icons.	Add an explicit "Go" button, manage focus in the dialog, and label the nav.
N8	Supabase preconnect is wasted	<code>layout.js:77</code> preconnects with <code>crossorigin</code> , but the images load without CORS, so the connection isn't reused.	Remove <code>crossorigin</code> .
N9	The image carousel described in the README never renders	<code>seo.js:53</code> caps <code>heroImages</code> at 1, so the carousel JS and dots are dead code.	Raise the cap, or remove the carousel code and README section.
N10	Duplicate meta descriptions on paginated pages	<code>router.js:104-108</code> : <code>/news/</code> and <code>/news/page/2/</code> have the same text.	Add "Page N" to the title and description.
N11	Article keywords are just the headline's words	JSON-LD <code>keywords</code> is, for example, <code>["delhi", "high", "court", "denies", "bail", "umar"]</code> .	Use real tags or entities, or omit the field.
N12	No timeout on Supabase calls (unverified)	<code>supabase.js:20</code> sets no fetch timeout while <code>maxDuration</code> is 10 s. A hung database would probably give a Vercel 504 instead of the branded 500.	Pass a <code>fetch</code> with <code>AbortSignal.timeout(7000)</code> .
N13	Not-yet-live posts may return 410 (unverified)	<code>queries.js:47-48</code> returns <code>gone</code> for any existing row that isn't live, including scheduled posts if they already have an id, and caches it for 5–15 minutes.	Return 410 only for rejected or unpublished posts; return 404 otherwise.
N14	Deep pagination offsets	Page numbers up to 9999 are accepted (offset about 300k). I didn't check the index on <code>published_id</code> .	Cap at the real page count; confirm the indexes exist.

ID	ISSUE	CAUSE / EVIDENCE	SUGGESTED FIX
E1	Local <code>dist/</code> is stale and built for the wrong project	The <code>dist/</code> bundle embeds the PixAgent URL for the support form (see H3). It's gitignored, but it would break the support form if deployed with <code>--prebuilt</code> .	Rebuild after fixing <code>.env</code> .

Checked and working

- Support form validation: empty and short name, bad email, missing topic, whitespace-only message all show the right message and focus the right field.
- Support form double-submit guard: 3 rapid submits sent 1 request. A network failure shows a clear fallback message.
- Support insert uses `.insert()` without `.select()`, which is correct under insert-only RLS. I found no value the client accepts that the database rejects.
- No service-role or secret keys in any built JS bundle; production `/.env` returns 404; `.env` is gitignored.
- Admin API: unauthenticated calls return 401, wrong login returns 401, and `/admin/dashboard/` redirects to login without a session. The dashboard escapes message HTML.
- `/news` routing: trailing-slash and canonical-slug 301s, wrong or uppercase slugs redirect to the canonical URL, and invalid pages and categories return 404.
- No open redirect: `//evil.com` and encoded variants stay on the same origin.
- `/news` escaping (apart from H1): body, meta and JSON-LD escape correctly, and U+2028/2029 are handled.
- Image host allowlist blocks foreign hosts and `javascript:` URLs.
- All JSON-LD blocks parse (5 static pages plus feed, hub and article pages). NewsArticle dates are ISO UTC and consistent.
- News caching per response type is sensible, and 500s aren't cached.
- News speed: 0.2–0.43 s on a cache miss, under 0.1 s on a hit; 3 queries per article, 1 per feed, no N+1 queries.
- All 14 sitemap URLs return 200, canonicals are www with a trailing slash, and http→https is a 308.
- Every internal link and image returns 200, apart from H5 and M16.
- One h1 per page, `lang` set, every image has alt text, no duplicate ids.
- No horizontal overflow at 375 px or 1280 px on `/`, `/news/`, `articles`, `/newsletter/`, `/support/` or `/admin/`.
- Resize handling is debounced and GSAP contexts are reverted; `three.js` is only loaded for `?capture`.
- `npm audit --omit=dev` finds 0 vulnerabilities; the production build succeeds.

Limits of this audit

- The admin panel isn't deployed, and I didn't use real admin credentials. Admin behaviour was tested with an isolated harness using fake values, plus unauthenticated requests to the dev server.
- The production support database (`hnt1ruqd1onpsoraxydk`) isn't in the Supabase account connected here, so I couldn't inspect its tables, RLS or advisors. PixAgent's security advisor reports no issues.
- I didn't submit forms to production or load-test anything. The newsletter edge function (another project) wasn't inspected.
- Browser tests ran in Chromium only; Safari/iOS and Firefox weren't tested. Screenshots taken while the preview pane was hidden sometimes caught animations mid-frame; those weren't counted as bugs.

Findings are labelled by severity: **C** critical, **H** high, **M** medium, and **L / N / E** low (general, news route and environment). File and line references are for the working tree on 30 September 2026.